

	Política de Contraseñas y Autenticación Segura	Fecha: 09/08/2026
Clasificación: Confidencial	Código: PO-SI-01	Versión: 1.0

POLÍTICA DE CONTRASEÑAS Y AUTENTICACIÓN SEGURA

Fondo Nacional de Vivienda Social (FNVs)



Registro de Cambios				
Versión	Páginas	Fecha	Descripción	Autor
1.0	6	09/08/2026	Política de Contraseñas y Autenticación Segura para el Fondo Nacional de Vivienda Social (FNVs)	Martin Alberto Benites Marin

Control documental		
	Preparado y revisado por	Aprobado por
Nombre/Rol	Martin Alberto Benites Marin / Ingeniero de Ciberseguridad	Alta Directiva
Fecha	09/08/2026	09/08/2026

	Política de Contraseñas y Autenticación Segura	Fecha: 09/08/2026
Clasificación: Confidencial	Código: PO-SI-01	Versión: 1.0

TABLA DE CONTENIDO

1. INTRODUCCIÓN	3
2. DEFINICIONES	3
3. ALCANCE.....	4
3.1. Alcance Lógico (Sistemas y Protocolos)	4
3.2. Alcance Humano (Usuarios).....	4
3.3. Exclusiones y Límites	4
3.4. Justificación del Alcance (Alineamiento ISO/IEC 27001)	4
4. OBJETIVOS	5
4.1. Objetivo General	5
4.2. Objetivos Específicos.....	5
5. POLÍTICA DE SEGURIDAD DE LA INFORMACIÓN	5
5a. Cuerpo de la política (Lineamientos).....	5
5b. Roles y Responsabilidades.....	6
5c. Cumplimiento y Revisión	6

	Política de Contraseñas y Autenticación Segura	Fecha: 09/08/2026
Clasificación: Confidencial	Código: PO-SI-01	Versión: 1.0

1. INTRODUCCIÓN

El objetivo de crear la Política de Contraseñas y Autenticación Segura para el Fondo Nacional de Vivienda Social (FNVS) es establecer la postura institucional y los compromisos técnicos para garantizar que el acceso a los activos de información sea robusto, controlado y proporcional al riesgo. Esta normativa surge ante un panorama de ciberamenazas en constante evolución, donde ejercicios de control interno han identificado vulnerabilidades críticas, tales como la susceptibilidad a ataques de fuerza bruta contra protocolos de comunicación y la ejecución de comandos no autorizados, lo cual pone en riesgo la confidencialidad e integridad de los datos financieros y personales gestionados por la entidad.

Para mitigar estos riesgos de manera estructurada, la presente política se alinea con los requisitos internacionales de la norma ISO/IEC 27001:2022 (específicamente en sus controles de información de autenticación y autenticación segura) y las funciones operativas de Gobernar y Proteger del NIST Cybersecurity Framework 2.0. A través de la implementación de estándares de complejidad, mecanismos de autenticación multifactor (MFA) y reglas de bloqueo de cuentas, el FNVS busca fortalecer su resiliencia organizacional y asegurar el cumplimiento de sus objetivos estratégicos bajo un marco de mejora continua.

2. DEFINICIONES

- **Activo de Información:** Todo aquello (como documentos digitales o físicos, servicios, aplicaciones y equipos) que es o contiene información que posee valor para la organización y que esta protege contra amenazas a su confidencialidad, integridad y disponibilidad.
- **Ataque de Fuerza Bruta:** Método automatizado que intenta obtener acceso no autorizado a un sistema probando sistemáticamente todas las combinaciones posibles de caracteres (letras, números y símbolos) hasta encontrar la credencial correcta.
- **Autenticación Multifactor (MFA):** Proceso de control de acceso que valida la identidad reclamada por un usuario mediante el uso exitoso de dos o más factores independientes: algo que el usuario sabe (ej. contraseña), algo que el usuario tiene (ej. token físico o digital) o algo que el usuario es (ej. huella dactilar).
- **Bloqueo de Cuenta:** Mecanismo de seguridad que inhabilita temporalmente el acceso a una cuenta de usuario tras detectarse un número predefinido de intentos de inicio de sesión fallidos, con el fin de frustrar intentos de acceso por fuerza bruta.
- **Control de Acceso:** Conjunto de reglas físicas y lógicas que restringen o permiten el uso de los activos de información basándose en los requisitos comerciales y de seguridad del FNVS, asegurando que solo el personal autorizado acceda a los recursos necesarios.
- **Credencial:** Datos o elementos utilizados para verificar la identidad de un usuario, servicio o equipo autorizado ante un sistema (p. ej., nombres de usuario, contraseñas, certificados digitales o datos biométricos).
- **Incidente de Seguridad:** Evento adverso que pone en peligro real o potencial la confidencialidad, integridad o disponibilidad de un sistema de información institucional o de los datos financieros y personales que este procesa, almacena o transmite.

	Política de Contraseñas y Autenticación Segura	Fecha: 09/08/2026
Clasificación: Confidencial	Código: PO-SI-01	Versión: 1.0

3. ALCANCE

Las disposiciones contenidas en este documento son de aplicación obligatoria para todas las partes interesadas (internos y externos), instalaciones y activos de información involucrados en los procesos estratégicos, operativos y de soporte de la entidad.

3.1. ALCANCE LÓGICO (SISTEMAS Y PROTOCOLOS)

Esta política aplica a todos los mecanismos de autenticación utilizados para acceder a la infraestructura tecnológica del FNVS, incluyendo de forma específica, pero no limitada a:

- **Servicios de Red y Compartición:** Protocolo SMB (Server Message Block) para el acceso a archivos institucionales.
- **Acceso Remoto y Administración:** Conexiones vía RDP (Remote Desktop Protocol), SSH (Secure Shell) y servicios de VPN (Virtual Private Network).
- **Cuentas Privilegiadas:** Todo acceso administrativo a servidores, bases de datos, dispositivos de red y consolas de gestión de herramientas de seguridad.

3.2. ALCANCE HUMANO (USUARIOS)

La política cubre a toda persona que requiera una credencial para interactuar con los activos del FNVS:

- **Personal Interno:** Empleados nombrados, contratados y funcionarios de todas las áreas.
- **Terceros y Proveedores:** Consultores externos, personal de outsourcing y proveedores de servicios de TI que posean acceso a la red o a información sensible del FNVS.

3.3. EXCLUSIONES Y LÍMITES

Quedan fuera del alcance de esta política:

- Sistemas o dispositivos personales de los empleados que no se utilicen para fines institucionales y que no tengan conexión con la red interna del FNVS (fuera del modelo BYOD).
- Información de dominio público que no requiera autenticación para su visualización en el portal web institucional.

3.4. JUSTIFICACIÓN DEL ALCANCE (ALINEAMIENTO ISO/IEC 27001)

Siguiendo los requisitos de la cláusula 4.3 de la norma ISO/IEC 27001:2022, los límites de esta política se han definido considerando las interfaces y dependencias entre las actividades del FNVS y sus proveedores externos, así como los requisitos legales y regulatorios propios de una entidad estatal financiera. La inclusión crítica de protocolos como SMB y RDP responde directamente al análisis de riesgos tras el incidente de laboratorio, donde se identificaron como vectores principales de amenazas de fuerza bruta que deben ser mitigados para proteger la misión de la organización.

	Política de Contraseñas y Autenticación Segura	Fecha: 09/08/2026
Clasificación: Confidencial	Código: PO-SI-01	Versión: 1.0

4. OBJETIVOS

4.1. OBJETIVO GENERAL

Establecer las directrices, estándares técnicos y controles administrativos para la gestión de identidades y la autenticación segura en el FNVS, con el fin de proteger los activos de información contra accesos no autorizados, mitigar el riesgo de ataques de fuerza bruta y asegurar el cumplimiento de la norma ISO/IEC 27001:2022.

4.2. OBJETIVOS ESPECÍFICOS

- **Garantizar la robustez de las credenciales:** Implementar requisitos obligatorios de complejidad, longitud y vigencia para todas las contraseñas utilizadas en la infraestructura tecnológica. (Vínculo: Protect - PR.AA).
- **Fortalecer el acceso a sistemas críticos:** Desplegar la autenticación multifactor (MFA) como control obligatorio para accesos remotos (VPN) y cuentas con privilegios administrativos. (Vínculo: Protect - PR.AA).
- **Prevenir ataques automatizados:** Establecer umbrales de bloqueo de cuentas tras intentos fallidos de inicio de sesión para neutralizar ataques de fuerza bruta y diccionario. (Vínculo: Protect - PR.AA).
- **Asegurar la visibilidad de eventos:** Mantener un monitoreo continuo de los logs de autenticación y registros de red para identificar patrones de tráfico anómalos de forma oportuna. (Vínculo: Detect - DE.CM).
- **Reducir la superficie de exposición:** Configurar restricciones a nivel de firewall para limitar el acceso a protocolos sensibles (SMB y RDP) únicamente desde segmentos de red autorizados. (Vínculo: Protect - PR.PS).
- **Fomentar la cultura de seguridad:** Capacitar periódicamente al personal y terceros en el tratamiento adecuado de la información de autenticación y los riesgos asociados al phishing. (Vínculo: Protect - PR.AT).

5. POLÍTICA DE SEGURIDAD DE LA INFORMACIÓN

5A. CUERPO DE LA POLÍTICA (LINEAMIENTOS)

1. **Robustez y Envejecimiento de Credenciales:** Toda contraseña de acceso a los sistemas del FNVS debe tener una longitud mínima de 10 caracteres, incluyendo mayúsculas, minúsculas, números y caracteres especiales. La vigencia máxima será de 90 días para usuarios estándar y 30 días para cuentas privilegiadas, prohibiendo la reutilización de las últimas 12 contraseñas. (Respaldo: Control A.5.17 Información de autenticación).
2. **Umbrales de Bloqueo de Cuenta:** Se implementará un mecanismo de bloqueo automático tras detectar 5 intentos fallidos de inicio de sesión en un periodo de 15 minutos. La cuenta permanecerá inhabilitada por al menos 30 minutos para mitigar ataques de fuerza bruta. (Respaldo: Control A.8.5 Autenticación segura).
3. **Seguridad en Protocolos de Red:** Queda restringido el acceso a los protocolos SMB (puerto 445) y RDP (puerto 3389) a través del perímetro de la red. El acceso a estos servicios se permitirá únicamente

	Política de Contraseñas y Autenticación Segura	Fecha: 09/08/2026
Clasificación: Confidencial	Código: PO-SI-01	Versión: 1.0

desde segmentos de red autorizados y estaciones de gestión seguras. (Respaldo: Control A.8.20 Seguridad de redes).

4. **Autenticación Multifactor (MFA):** Es obligatorio el uso de al menos dos factores de verificación independientes para todos los accesos remotos vía VPN y para cualquier inicio de sesión en cuentas con privilegios administrativos. (Respaldo: Control A.8.5 Autenticación segura).
5. **Vigilancia de Eventos de Seguridad:** El FNVS mantendrá un monitoreo continuo de los registros de autenticación y tráfico de red mediante una solución SIEM. El sistema debe estar configurado para generar alertas ante comportamientos anómalos o intentos de intrusión en tiempo real. (Respaldo: Control A.8.16 Actividades de supervisión).

5B. ROLES Y RESPONSABILIDADES

- **Alta Dirección:** Responsable de demostrar liderazgo, aprobar la política y garantizar que los objetivos de seguridad estén alineados con la estrategia institucional del FNVS.
- **Oficial de Seguridad de la Información (CISO):** Encargado de liderar el programa de ciberseguridad, gestionar los riesgos y supervisar que los controles de autenticación se apliquen correctamente en toda la entidad.
- **Área de Tecnologías de la Información (TI):** Responsable de la implementación técnica de los controles (MFA, firewalls, configuraciones de SIEM) y de asegurar que los sistemas operen bajo los estándares de seguridad definidos.
- **Usuarios Finales (Personal y Terceros):** Tienen la obligación de conocer y cumplir las directrices de esta política, tratar sus credenciales de forma confidencial y reportar cualquier incidente o sospecha de compromiso de su cuenta de forma inmediata.

5C. CUMPLIMIENTO Y REVISIÓN

- **CUMPLIMIENTO:** El incumplimiento de las disposiciones de esta política será considerado una falta sujeta a medidas disciplinarias según la gravedad de la infracción. Estas medidas pueden ir desde amonestaciones verbales o escritas hasta la suspensión o terminación del vínculo laboral/contractual, conforme a las normas de Recursos Humanos y el marco legal vigente. (Respaldo: Control A.6.4 Proceso disciplinario).
- **REVISIÓN:** Bajo el enfoque del ciclo de mejora continua (PDCA), esta política será revisada de forma independiente y actualizada en intervalos planificados, siendo la periodicidad mínima anual. Asimismo, se realizará una revisión extraordinaria ante cambios significativos en la infraestructura tecnológica o tras la ocurrencia de incidentes de seguridad críticos. (Respaldo: Control A.5.1 Políticas de seguridad de la información).